

VaNiBase + KI-Prime

Auth & Onboarding PRD

Product Requirements Document

Version 1.0 | March 28, 2026
Vikuna Technologies
Charan Kamal Bommakanti | Architect: Claude.ai

Field	Value
Document	Auth & Onboarding PRD
Product	VaNiBase Framework + KI-Prime
Version	1.0
Date	March 28, 2026
Status	Draft — Ready for Claude Code
Scope	Registration, Login, JWT Auth, Onboarding Wizard, Invitations, Password Management, Session Management
Prototypes	documents/HTML/auth-onboard/ (6 HTML files)

Table of Contents

1. Executive Summary
2. Architecture Overview
3. Storage & Upload Strategy
4. User Stories (US-01 to US-15)
5. Database Schema
6. Onboarding Wizard Specification
7. Theme Resolution
8. Subscription & Business Model
9. HTML Prototype Reference
10. API Endpoint Summary
11. Validation Rules Summary
12. Future Scope

1. Executive Summary

This PRD defines the complete authentication, authorization, and onboarding system for VaNiBase (the multi-tenant SaaS framework) and KI-Prime (the first product built on it). It serves as the binding specification for Claude Code sessions implementing these features.

The system operates in three layers:

- Layer 1 (VaNiBase Framework): Registration, JWT auth, session management, invite system, password management, protected routes, auth middleware. All products inherit this.
- Layer 2 (VaNiBase Onboarding): Configurable wizard framework with step tracking, mandatory/optional steps, product-level step injection via ShellConfig.
- Layer 3 (KI-Prime Product): Custom Atlas login page, product-specific onboarding steps (risk preferences, scheme preferences, data import), KI_ table migrations.

Key design principles: frictionless registration (4 fields only), owner-centric onboarding (only the tenant owner completes the wizard), hard-block for invited users until onboarding completes, theme-enabled pages via CSS variables, and Firebase stopgap storage for uploads.

2. Architecture Overview

2.1 Three-Layer Model

VaNiBase uses a layered architecture where the framework provides core auth and onboarding infrastructure, and products extend it with custom behavior.

Layer	Scope	Owner
VaNiBase Framework	Registration, Login/Logout, JWT lifecycle, Session management, Invite system, Forgot password, Auth middleware, Protected routes, Onboarding framework (wizard component, step tracker)	VaNiBase repo
VaNiBase Onboarding	VN_tenant_onboarding table, Wizard renderer from ShellConfig.onboarding.steps[], Default steps: User Profile + Business Profile, Theme selection, Invite team	VaNiBase repo
KI-Prime Product	Custom login (Atlas vault), Product onboarding steps: Risk/Scheme Preferences + Import Data, KI_ table migrations, Default theme: vikuna-black	KI-Prime repo

2.2 Auth Flow

Register (4 fields) -> Auto-create tenant + user + starter subscription + owner role -> Redirect to /onboarding -> Complete mandatory steps -> Redirect to /dashboard. Returning users: Login -> JWT issued -> Theme applied -> If onboarding incomplete redirect to /onboarding else redirect to /dashboard.

2.3 Token Lifecycle

- Access token: 15 minutes, stored in memory + sessionStorage
- Refresh token: 30 days, SHA-256 hashed in VN_refresh_tokens
- Silent refresh: 2 minutes before expiry
- On tab close: sessionStorage cleared, token gone
- Token rotation: new refresh token on each refresh call

2.4 Session Enforcement

- max_sessions read from VN_subscriptions tier
- Login checks active session count; returns 409 if limit exceeded
- 409 response includes list of active sessions for user to revoke one
- Device capture: IP, browser, OS, device_type parsed from User-Agent

2.5 Handler Signature

All skill handlers follow: (params, ctx) where params is FIRST, ctx (SkillContext with tenant_id, user_id) is SECOND. Auth middleware extracts these from JWT and injects into context.

3. Storage & Upload Strategy

3.1 MVP Approach (Firebase Stopgap)

- .env flag: STORAGE_ENABLED=true/false (product-level opt-in)
- .env: UPLOAD_ENDPOINT=<firebase-storage-url>
- Client uploads directly to Firebase, receives URL back
- URL saved to entity fields: VN_users.avatar_url, VN_tenant_profiles.logo_url
- No server-side file handling in VaNiBase for MVP
- No VN_files table for MVP - URLs stored inline on entities

3.2 File Types

File	Entity Field	Max Size	Formats
User avatar	VN_users.avatar_url	2 MB	JPG, PNG
Firm logo	VN_tenant_profiles.logo_url	2 MB	JPG, PNG, SVG
CAS import	Processed on upload, not stored long-term	10 MB	PDF, CSV

3.3 Future Storage Options

- VPS filesystem with structured paths (/data/{tenant_id}/...)
- User-configurable external storage (Google Drive, S3, MinIO)
- Pluggable adapter pattern: swap .env URL + adapter, no schema change

4. User Stories

US-01: New MFD Registers Firm

*As a **new MFD/RIA/IFA**, I want to register my account with minimal friction, so that I can start using KI-Prime immediately.*

Acceptance Criteria:

- Registration form shows only: Full Name, Email, Password (with strength meter), Confirm Password, Phone (country code + mobile)
- On submit: tenant created, user created with owner role, starter subscription auto-created
- Password validated: min 8 chars, 1 uppercase, 1 number; bcrypt 12 rounds
- Email must be unique system-wide (case-insensitive)
- Phone stores country code + number separately
- After success: redirect to /onboarding
- Terms checkbox required before submit

API Endpoint:

POST /api/v1/auth/register - Body: { name, email, password, phone: { country_code, number } } - Response: { access_token, refresh_token, user, tenant }

Validation Rules:

- Email: unique system-wide, case-insensitive, RFC 5322 format, validated client + server
- Password: min 8, max 128, 1 uppercase, 1 number, strength meter client-side, bcrypt 12 server-side
- Phone: country_code (+ prefix, 1-4 digits), number (digits only, 6-15 length)
- Name: 2-100 chars, trimmed, XSS sanitized
- All fields: XSS sanitization, trim, max length enforced both client and server

VDF Components:

form-input, button (submit), password strength meter (custom), country dropdown (custom with flag images)

Prototype Reference: documents/HTML/auth-onboard/atlas-register.html

Owner: VaNiBase

Dependencies: VN_tenants, VN_users, VN_subscriptions, VN_roles, VN_user_roles tables

US-02: Owner Completes Onboarding Wizard

*As a **tenant owner**, I want to complete the onboarding wizard, so that my workspace is configured and my team can access the product.*

Acceptance Criteria:

- After registration, owner is redirected to /onboarding
- Wizard shows 6 steps (KI-Prime): User Profile, Business Profile, Theme, Invite Team, Risk Preferences, Import Data
- Steps 1-2 are mandatory; steps 3-6 are optional/skippable

- Step progress tracked in VN_tenant_onboarding table
- Owner can navigate forward/back between steps
- Clicking step dots in indicator navigates directly
- On completion of all mandatory steps: tenant marked as onboarded, redirect to /dashboard
- Incomplete onboarding: on next login, redirect back to wizard at last incomplete step
- Only the tenant owner sees/completes the wizard; invited users never see it

API Endpoint:

PATCH /api/v1/onboarding/step - Body: { step_id, step_data, status } - Response: { step, next_step, onboarding_complete }

VDF Components:

wizard (VDF), form-input, button, photo upload zone, theme-card grid, chip selector

Prototype Reference: documents/HTML/auth-onboard/atlas-onboarding.html

Owner: VaNiBase (framework) + KI-Prime (product steps)

Dependencies: US-01 (registration), VN_tenant_onboarding table, ShellConfig.onboarding.steps[]

US-03: Returning User Logs In

*As a **returning user**, I want to log in with my credentials, so that I can access my dashboard with my theme applied.*

Acceptance Criteria:

- Login form: email + password (product can override with custom login component)
- On success: JWT pair issued (access 15min, refresh 30 days)
- Device info captured: IP, browser, OS, device_type from User-Agent
- Theme resolution: user pref > tenant config > ShellConfig.theme.default > framework fallback (classic-elegant)
- Redirect to /dashboard (or /onboarding if incomplete)
- Session count checked against subscription tier max_sessions

API Endpoint:

POST /api/v1/auth/login - Body: { email, password } - Response: { access_token, refresh_token, user: { id, name, email, tenant_id, roles, preferences }, tenant: { id, name, theme_id } }

Validation Rules:

- Email: case-insensitive lookup
- Account lockout: 5 failed attempts = 15 min lockout

VDF Components:

Product-level login override via ShellConfig.pages.login (KI-Prime uses LoginVault)

Prototype Reference: documents/HTML/auth-onboard/ (existing 01-login-vault.html in KI-Prime prototypes)

Owner: VaNiBase

Dependencies: VN_users, VN_refresh_tokens, VN_subscriptions

US-04: Returning User with Incomplete Onboarding

*As a **returning user (owner)**, I want to be redirected to complete onboarding, so that the workspace setup is completed before I or my team can use the product.*

Acceptance Criteria:

- After login, check VN_tenant_onboarding for incomplete mandatory steps
- If any mandatory step is incomplete: redirect to /onboarding at the first incomplete step
- Wizard pre-fills previously completed steps (navigable via step dots)
- This check happens on every login until all mandatory steps are done

API Endpoint:

GET /api/v1/onboarding/status - Response: { complete: boolean, steps: [{ id, status, mandatory }], next_incomplete_step }

VDF Components:

wizard (VDF) with pre-filled state

Owner: VaNiBase

Dependencies: US-02 (onboarding), VN_tenant_onboarding

US-05: Token Refreshes Silently

*As a **logged-in user**, I want to have my session refreshed automatically, so that I am not interrupted during work.*

Acceptance Criteria:

- AuthProvider schedules refresh 2 minutes before access token expiry
- Refresh call sends current refresh token, receives new token pair
- Old refresh token is invalidated (token rotation)
- If refresh fails (expired/revoked): redirect to /login
- No UI indication during silent refresh

API Endpoint:

POST /api/v1/auth/refresh - Body: { refresh_token } - Response: { access_token, refresh_token }

VDF Components:

AuthProvider (context), no visible UI

Owner: VaNiBase

Dependencies: VN_refresh_tokens

US-06: User Logs Out

*As a **logged-in user**, I want to log out of my session, so that my session is securely terminated.*

Acceptance Criteria:

- Logout revokes the current refresh token in VN_refresh_tokens
- Access token removed from memory and sessionStorage
- Redirect to /login
- Other active sessions on other devices remain unaffected

API Endpoint:

POST /api/v1/auth/logout - Body: { refresh_token } - Response: { success: true }

VDF Components:

sidebar logout button, auth context clearSession()

Owner: VaNiBase

Dependencies: VN_refresh_tokens

US-07: User Hits Session Limit

*As a **user trying to log in**, I want to see my active sessions and revoke one, so that I can free up a slot to log in on this device.*

Acceptance Criteria:

- Login returns 409 when active session count $\geq$ max_sessions from subscription tier
- 409 response body includes list of active sessions: { sessions: [{ id, device_type, browser, os, ip, last_active }] }
- User selects a session to revoke, then login proceeds
- Revoke requires email + password (not Bearer token, since user is not yet authenticated)

API Endpoint:

POST /api/v1/auth/sessions/revoke - Body: { email, password, session_id } OR { Authorization: Bearer, session_id }

VDF Components:

modal with session list, revoke button per session

Prototype Reference: documents/HTML/auth-onboard/atlas-settings.html (Sessions tab)

Owner: VaNiBase

Dependencies: VN_refresh_tokens, VN_subscriptions

US-08: Tenant Theme Applies to All Users

*As a **tenant admin**, I want to set a theme that applies to all tenant users, so that the workspace has a consistent visual identity.*

Acceptance Criteria:

- Tenant theme stored in VN_tenant_profiles.theme_id
- On login, tenant.theme_id returned in login response
- ThemeProvider resolves: user pref > tenant config > product default > framework fallback
- Admin updates tenant theme via settings (or onboarding step 3)

API Endpoint:

PATCH /api/v1/tenant/profile - Body: { theme_id } - Response: { tenant_profile }

Validation Rules:

- theme_id must be a valid theme from the registry (12 themes)

VDF Components:

ThemeProvider, theme-card selector grid

Prototype Reference: documents/HTML/auth-onboard/atlas-onboarding.html (Step 3) and atlas-settings.html (Appearance tab)

Owner: VaNiBase

Dependencies: VN_tenant_profiles, theme registry

US-09: User Overrides Tenant Theme

*As a **individual user**, I want to choose my own theme preference, so that I can customize my workspace without affecting others.*

Acceptance Criteria:

- User theme stored in VN_users.preferences.theme_override (JSONB field)
- Also cached in localStorage for instant apply
- Theme resolution: user pref (highest priority) > tenant config > product default > framework fallback
- Reset option: "Reset to Tenant Default" clears the override

API Endpoint:

PATCH /api/v1/auth/preferences - Body: { theme_override: "ocean-depth" } - Response: { preferences }

Validation Rules:

- theme_override must be valid theme ID or null (to reset)

VDF Components:

theme-card grid in settings, "Reset to Tenant Default" button

Prototype Reference: documents/HTML/auth-onboard/atlas-settings.html (Appearance tab)

Owner: VaNiBase

Dependencies: VN_users.preferences JSONB

US-10: Tenant Owner Invites Team Member

As a **tenant owner**, I want to invite team members by email with a specific role, so that my team can join the workspace.

Acceptance Criteria:

- Owner enters email + role (Admin or Planner) for each invitee
- System creates record in VN_invitations with token_hash, role_id, expires_at (7 days)
- Email sent with invitation link (MVP: token in API response, email dispatch later)
- Multiple invites can be sent at once (batch)
- Duplicate email for same tenant returns error
- Invitees are blocked from workspace until owner completes all mandatory onboarding steps

API Endpoint:

POST /api/v1/auth/invite - Body: { invitations: [{ email, role_id }] } - Response: { invitations: [{ id, email, role, token, status, expires_at }] }

Validation Rules:

- Email: valid format, not already a member of this tenant
- Role: must be valid role_id from VN_roles

VDF Components:

invite row (email input + role select + remove button), add-invite button

Prototype Reference: documents/HTML/auth-onboard/atlas-onboarding.html (Step 4) and atlas-invite-join.html

Owner: VaNiBase

Dependencies: VN_invitations, VN_roles

US-11: Existing User Accepts Invitation

As a **existing KI-Prime user**, I want to accept an invitation to join another tenant, so that I can work within that firm workspace with my assigned role.

Acceptance Criteria:

- User clicks invite link, system recognizes their email as existing user
- Shows invitation context: firm name, role, invited by
- Shows user profile card (avatar, name, email, verified badge)
- Shows perks of joining
- On "Accept": VN_user_roles entry created, VN_invitations status updated to accepted
- Redirect to dashboard of the new tenant

API Endpoint:

POST /api/v1/auth/invite/accept - Body: { token } - Headers: Authorization: Bearer - Response: { user, tenant, role }

Validation Rules:

- Token must be valid and not expired
- User must not already be a member of the tenant

VDF Components:

invitation banner, user profile card, accept button

Prototype Reference: documents/HTML/auth-onboard/atlas-invite-join.html (Existing User view)

Owner: VaNiBase

Dependencies: VN_invitations, VN_user_roles

US-12: New User Registers via Invitation

*As a **new user (not on platform)**, I want to register and join a tenant via invitation link, so that I can create my account and immediately join the firm.*

Acceptance Criteria:

- User clicks invite link, system does not find their email
- Shows invitation context: firm name, role, invited by
- Shows registration form: name, email (pre-filled + readonly from invite), password, confirm password, phone
- On submit: user created + VN_user_roles entry created + VN_invitations updated
- No new tenant created (they join existing tenant)
- Redirect to dashboard (not onboarding - only owners do onboarding)

API Endpoint:

POST /api/v1/auth/invite/accept - Body: { token, name, password, phone } - Response: { access_token, refresh_token, user, tenant, role }

Validation Rules:

- Same validation as registration: password strength, email format, phone format
- Email must match invitation email exactly

VDF Components:

invitation banner, registration form with pre-filled email

Prototype Reference: documents/HTML/auth-onboard/atlas-invite-join.html (New User view)

Owner: VaNiBase

Dependencies: VN_invitations, VN_users, VN_user_roles

US-13: Tenant Admin Views Pending Invitations

*As a **tenant owner/admin**, I want to see pending invitations and revoke them, so that I can manage who has access to my workspace.*

Acceptance Criteria:

- List shows: email, role, invited by, status (pending/accepted/expired/revoked), sent date, expiry date
- Owner can revoke pending invitations
- Revoking invalidates the token
- Expired invitations shown with expired status

API Endpoint:

GET /api/v1/auth/invitations - Query: { status } - Response: { invitations: [...] }. DELETE /api/v1/auth/invitations/:id for revoke.

VDF Components:

data-table (VDF), badge (status), revoke button

Owner: VaNiBase

Dependencies: VN_invitations

US-14: System Enforces Email Uniqueness

*As a **system**, I want to enforce email uniqueness across the platform, so that no duplicate accounts exist.*

Acceptance Criteria:

- VN_users.email has UNIQUE constraint
- Email stored lowercase (case-insensitive)
- Registration checks uniqueness before insert
- Invite acceptance for new users checks uniqueness
- Error message: "An account with this email already exists"

API Endpoint:

Enforced at database level (UNIQUE constraint) and application level (pre-check)

Validation Rules:

- Email normalized to lowercase before comparison
- Trim whitespace before validation

Owner: VaNiBase

Dependencies: VN_users

US-15: System Enforces Subscription Limits

*As a **system**, I want to enforce subscription tier limits on every skill call, so that free tier users are rate-limited and paid features are gated.*

Acceptance Criteria:

- VN_subscriptions stores: tier, max_sessions, rate_limit, features JSONB
- Auth middleware reads subscription on every request

- max_sessions checked on login
- Rate limiting reads tier on every API call (already built in gateway)
- MVP: auto-create starter tier on registration, no payment flow
- Future: payment integration, upgrade/downgrade flows

API Endpoint:

Read from VN_subscriptions via auth middleware on every /api/v1/skills/* call

Owner: VaNiBase

Dependencies: VN_subscriptions, auth middleware

5. Database Schema

5.1 Existing VN_ Tables (10)

Already built: VN_tenants, VN_tenant_profiles, VN_users, VN_roles, VN_user_roles, VN_refresh_tokens, VN_subscriptions, VN_subscription_history, VN_audit_log, VN_migrations.

5.2 New Tables

VN_invitations

Column	Type	Constraints	Notes
id	UUID	PK, DEFAULT gen_random_uuid()	
email	VARCHAR(255)	NOT NULL	Invitee email
tenant_id	UUID	FK -> VN_tenants, NOT NULL	
role_id	UUID	FK -> VN_roles, NOT NULL	Role assigned on acceptance
invited_by	UUID	FK -> VN_users, NOT NULL	User who sent invite
token_hash	VARCHAR(64)	NOT NULL, UNIQUE	SHA-256 hash of invite token
status	VARCHAR(20)	DEFAULT pending	pending, accepted, expired, revoked
expires_at	TIMESTAMPTZ	NOT NULL	Default: now() + 7 days
accepted_at	TIMESTAMPTZ	NULL	Timestamp of acceptance
created_at	TIMESTAMPTZ	DEFAULT now()	

VN_password_resets

Column	Type	Constraints	Notes
id	UUID	PK, DEFAULT gen_random_uuid()	
user_id	UUID	FK -> VN_users, NOT NULL	
token_hash	VARCHAR(64)	NOT NULL, UNIQUE	SHA-256 hash
expires_at	TIMESTAMPTZ	NOT NULL	Default: now() + 30 min
used_at	TIMESTAMPTZ	NULL	Marked when used
created_at	TIMESTAMPTZ	DEFAULT now()	

VN_tenant_onboarding

Column	Type	Constraints	Notes
id	UUID	PK, DEFAULT gen_random_uuid()	

tenant_id	UUID	FK -> VN_tenants, NOT NULL	
step_id	VARCHAR(50)	NOT NULL	e.g. user_profile, business_profile, theme
step_sequence	INTEGER	NOT NULL	Order in wizard
step_status	VARCHAR(20)	DEFAULT pending	pending, completed, skipped
mandatory	BOOLEAN	DEFAULT true	Must complete to finish onboarding
metadata	JSONB	DEFAULT {}	Step-specific data
completed_at	TIMESTAMPTZ	NULL	
created_at	TIMESTAMPTZ	DEFAULT now()	

5.3 Schema Changes to Existing Tables

- VN_users: Add avatar_url VARCHAR(500) NULL
- VN_tenant_profiles: Add logo_url VARCHAR(500) NULL
- VN_tenant_profiles: Ensure theme_id VARCHAR(50) exists

6. Onboarding Wizard Specification

6.1 Framework Design

- Steps defined in `ShellConfig.onboarding.steps[]` - each product configures its own steps
- VaNiBase provides default steps: `user_profile`, `business_profile`
- Products add custom steps (KI-Prime adds: `theme`, `invite_team`, `risk_preferences`, `import_data`)
- Each step maps to a CRUD operation (profile update, theme selection, invite creation, etc.)
- Step progress persisted in `VN_tenant_onboarding`
- Only tenant owner sees/completes the wizard
- Invited users see hard-block "onboarding pending" screen

6.2 KI-Prime Steps

#	Step ID	Title	Mandatory	Layout	CRUD Target
1	<code>user_profile</code>	User Profile	Yes	Split-panel	PATCH <code>/api/v1/auth/me</code> (name, designation, phone, bio, avatar_url)
2	<code>business_profile</code>	Business Profile	Yes	Split-panel	PATCH <code>/api/v1/tenant/profile</code> (firm name, type, ARN, PAN, GSTIN, address, logo_url)
3	<code>theme_selection</code>	Theme	No (default: vikuna-black)	Full-width	PATCH <code>/api/v1/tenant/profile</code> (theme_id)
4	<code>invite_team</code>	Invite Team	No	Split-panel	POST <code>/api/v1/auth/invite</code> (batch invites)
5	<code>risk_preferences</code>	Risk/Scheme Prefs	No	Split-panel	PATCH <code>/api/v1/tenant/preferences</code> (KI-Prime specific JSONB)
6	<code>import_data</code>	Import Data	No	Full-width	POST <code>/api/v1/skills/import</code> (KI_IMPORT skill)

6.3 ShellConfig Integration

In `shell.config.ts`, the onboarding steps are configured as:

```
onboarding: { steps: [ { id: "user_profile", title: "Your Profile", mandatory: true, component: "OnboardUserProfile" }, { id: "business_profile", title: "Business Details", mandatory: true, component: "OnboardBusiness" }, { id: "theme_selection", title: "Theme", mandatory: false, default: "vikuna-black", component: "OnboardTheme" }, { id: "invite_team", title: "Invite Team", mandatory: false, component: "OnboardInvite" }, { id: "risk_preferences", title: "Preferences", mandatory: false, component: "OnboardPreferences" }, { id: "import_data", title: "Import Data", mandatory: false, component: "OnboardImport" } ] }
```

6.4 Onboarding Pending (Invited Users)

- If an invited user logs in and the tenant onboarding is not complete, they see a hard-block screen
- Screen shows: hourglass icon, "Workspace setup in progress" message, which steps are done/pending, owner name
- No access to any product features until owner completes all mandatory steps

- Prototype: atlas-onboarding.html (toggle "Pending Block" in top-right)

7. Theme Resolution

The theme system uses a 4-level resolution chain, evaluated top-to-bottom. First non-null value wins.

Priority	Source	Storage	Set By
1 (highest)	User preference	VN_users.preferences.theme_override (JSONB) + localStorage	User via Settings > Appearance
2	Tenant config	VN_tenant_profiles.theme_id	Owner via Onboarding Step 3 or Settings
3	Product default	ShellConfig.theme.default (in shell.config.ts)	Coded per product (vikuna-black for KI-Prime)
4 (fallback)	Framework fallback	Hardcoded in theme registry	classic-elegant (never changes)

8. Subscription & Business Model (MVP)

- On registration: auto-create "starter" tier in VN_subscriptions
- Starter tier: max_sessions = 2, basic rate limits, core features enabled
- No payment flow in MVP
- Rate limiting reads tier on every API call (already built in auth middleware)
- Future: payment integration, upgrade/downgrade, plan comparison page

9. HTML Prototype Reference

All prototypes are in documents/HTML/auth-onboard/ and use the Atlas design system with CSS variables mapped to the VaNiBase theme system.

File	Page	Layout	Key Features
atlas-register.html	Registration	Split-panel	Frictionless 4 fields, password strength meter, country flag dropdown, orbit ring animation
atlas-forgot-password.html	Forgot Password	Centered card	Email input, success state with animated checkmark, resend link micro-interaction
atlas-invite-join.html	Join Tenant (Type A)	Centered card	Two views (New User / Existing User) via toggle, invitation banner, registration form / accept button
atlas-invite-referral.html	Referral Signup (Type B)	Split-panel	Referrer card with quote + stats on left, standard registration on right, referral badge
atlas-onboarding.html	Onboarding Wizard	6-step wizard	6 steps with split/full layouts, step indicator, theme grid, invite team, chip selectors, pending block screen
atlas-settings.html	Settings / Profile	Shell + tabs	4 tabs: Profile, Security (change password), Appearance (theme), Sessions (revoke). Danger zone.

10. API Endpoint Summary

Endpoint	Method	Auth	Status	User Story
/api/v1/auth/register	POST	Public	Built	US-01
/api/v1/auth/login	POST	Public	Built	US-03
/api/v1/auth/refresh	POST	Public	Built	US-05
/api/v1/auth/logout	POST	Public	Built	US-06
/api/v1/auth/sessions/revoke	POST	email+pw OR Bearer	Built	US-07
/api/v1/auth/preferences	PATCH	Bearer	Built	US-09
/api/v1/auth/me	GET	Bearer	Built	US-02
/api/v1/auth/forgot-password	POST	Public	To Build	Future
/api/v1/auth/reset-password	POST	Public	To Build	Future
/api/v1/auth/invite	POST	Bearer (owner)	To Build	US-10
/api/v1/auth/invite/accept	POST	Public or Bearer	To Build	US-11, US-12
/api/v1/auth/invitations	GET	Bearer (owner/admin)	To Build	US-13
/api/v1/auth/invitations/:id	DELETE	Bearer (owner)	To Build	US-13
/api/v1/onboarding/status	GET	Bearer	To Build	US-04
/api/v1/onboarding/step	PATCH	Bearer (owner)	To Build	US-02
/api/v1/tenant/profile	PATCH	Bearer (owner/admin)	To Build	US-08
/api/v1/auth/change-password	POST	Bearer	To Build	Settings

11. Validation Rules Summary

Field	Client Validation	Server Validation
Email	Format check, required	Unique system-wide (case-insensitive), RFC 5322, trim, lowercase, max 255
Password	Min 8, 1 uppercase, 1 number, strength meter	Min 8, max 128, 1 uppercase, 1 number, bcrypt 12 rounds
Confirm Password	Match check against password field	N/A (client only)
Phone - Country Code	+ prefix, dropdown selection	1-4 digits after +, validated against known codes
Phone - Number	Digits only, auto-format with space	6-15 digits, digits only
Full Name	Required, min 2 chars	2-100 chars, trimmed, XSS sanitized
Firm Name	Required, min 3 chars	3-100 chars, unique slug auto-generated, trimmed
PAN (KI-Prime)	ABCDE1234F format mask	Regex: [A-Z]{5}[0-9]{4}[A-Z], unique per tenant, uppercase
GSTIN	Optional, format hint	15 chars alphanumeric, optional
ARN	ARN-XXXXXX format	Validated format, optional uniqueness check
All fields	Max length, trim on blur	XSS sanitization (strip HTML tags), trim, max length

12. Future Scope (Out of MVP)

- Email verification flow (is_email_verified column exists, no flow yet)
- Email dispatch for invitations (MVP: token in API response)
- Email dispatch for password reset
- Payment integration / subscription upgrade-downgrade
- OAuth/SSO (Google, GitHub)
- RLS (Row-Level Security) on all tables
- Max sessions cleanup cron
- Pluggable storage adapter (VPS, S3, Google Drive)
- Type B invite tracking / referral credits
- Two-factor authentication (2FA)
- Audit log for all auth events
- Rate limit dashboard for admins

--- End of Document ---